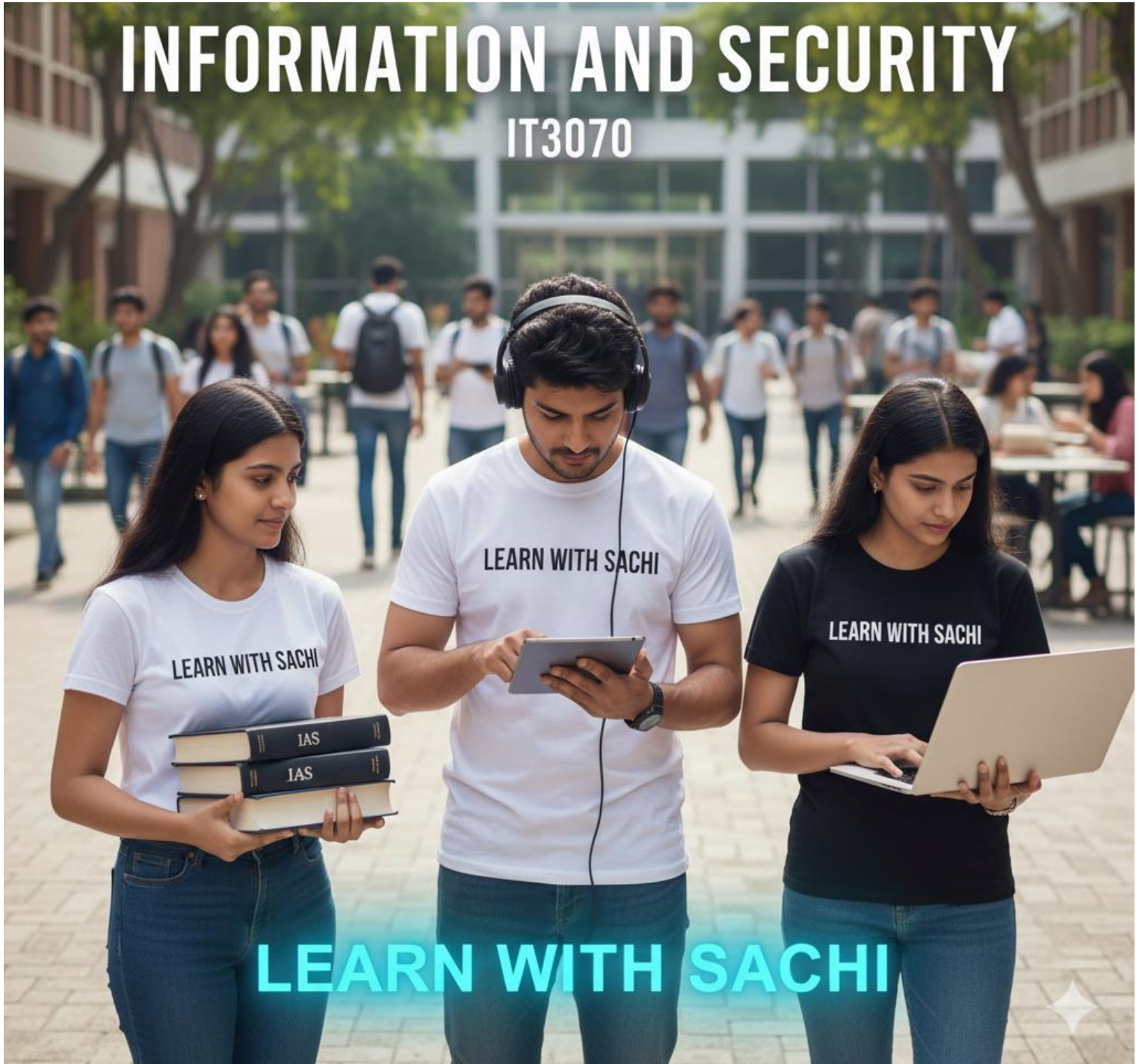


INFORMATION AND SECURITY

IT3070



Contents

1)	Lecture 1: Introduction to information security	2
2)	Lecture 2: Introduction to information security – Part II	5
3)	Lecture 3: Information Risk Management – GRC & COBIT.....	9
4)	Lecture 3 Part 2: Information Risk Management – GRC & COBIT	12
5)	Lecture 4: OCTAVE Risk Evaluation Framework.....	16
6)	Lecture 5: Introduction to Cryptography & Historical Ciphers	21
7)	Lecture 6: Symmetric Ciphers	24
8)	Lecture 7: Public Key Cryptography (Asymmetric Encryption).....	28
9)	Lecture 8: Hash Functions & MACs	33
10)	Lecture 9: Access control	37
11)	Lecture 10: User Authentication.....	41
12)	Lecture 11: Firewalls, ACLs & Network Security	45
13)	Lecture 12: Disaster Recovery & Business Continuity Planning (DRP & BCP)	51

1) Lecture 1: Introduction to information security

◆ 1. Core Concepts

Concept	Description
Computer Security	Protection of information system resources (hardware, software, data, communication) ensuring CIA .
Information Security (InfoSec)	Protects information and systems from unauthorized access, use, disclosure, disruption, modification, or destruction.
Information Assurance (IA)	Ensures availability, integrity, authentication, confidentiality, and non-repudiation through protection, detection, and reaction capabilities.

◆ 2. The CIA Triad

Element	Meaning	Loss implies
Confidentiality (C)	Prevent unauthorized disclosure of data. Includes <i>data confidentiality</i> and <i>privacy</i> .	Data leaks / unauthorized access
Integrity (I)	Maintain correctness and trustworthiness of information and systems.	Unauthorized modification or destruction
Availability (A)	Ensure timely, reliable access to data and systems.	Denial of service / inaccessibility

Additional Goals:

- **Authenticity:** Verify identity and data source.
- **Accountability:** Trace actions to responsible entities (supports non-repudiation & forensics).

◆ 3. Computer Security Model

Component	Description
Resources / Assets	Hardware, Software, Data, Networks.
Vulnerabilities	Weakness exploitable to violate CIA.
Threats	Potential dangers exploiting vulnerabilities.
Attacks	Actual execution of a threat (active or passive).
Adversary	The attacker or threat agent.
Countermeasures	Prevent, detect, or recover from attacks.
Risk	Expected loss from an attack.

◆ 4. Attack Classification

Type	Description	Examples
Passive	Eavesdropping / monitoring without altering data.	Message interception, traffic analysis.
Active	Alters or affects system operation.	Replay, masquerade, modification, DoS.
Inside Attacks	From internal users (employees).	Data theft, infected USBs.
Outside Attacks	From external unauthorized users.	DoS via internet, intrusion.

◆ 5. Testing & Risk Analysis

Term	Explanation
Exploit	Software or method used to take advantage of a vulnerability.
Vulnerability Assessment	Identify and prioritize vulnerabilities within systems or networks.
Penetration Testing	Ethical hacking to find and test vulnerabilities.
Goal of Pen Testing	Identify weak points, verify policy compliance, assess staff awareness, and gauge risk exposure.



Computer Security Model

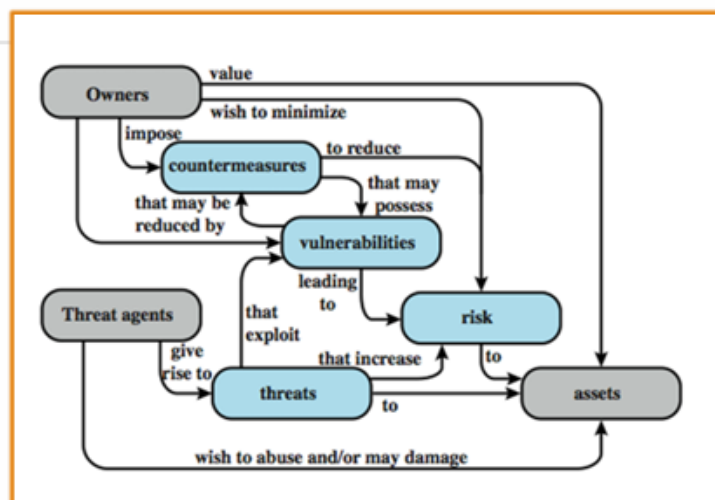


Figure from Stallings & Brown textbook

2) Lecture 2: Introduction to information security – Part II

◆ 1. Security Controls

Category	Description	Examples
Physical Controls	Tangible protections to prevent unauthorized physical access.	CCTV, alarms, ID cards, guards, locked doors, segregation.
Technical / Logical Controls	Technology-based methods controlling access & data usage.	Encryption, smart cards, ACLs, network authentication, file integrity checkers.
Administrative Controls	Human & procedural controls defining access rights, policies, and training.	Security policies, DR plans, recruitment process, awareness training.

◆ 2. Controls by Functionality

Type	Purpose	Example
Preventive	Stop incidents before happening.	Separation of duties, proper hiring, approvals.
Detective	Discover events after they occur.	Log reviews, alarms, audits.
Deterrent	Discourage attempts by showing readiness.	“This area monitored” notices, visible security.
Corrective	Fix issues after violation.	Remove virus, update firewall rules.
Recovery	Restore operations after severe impact.	Backups, BCP, DR mechanisms.
Compensating	Substitute when main control fails.	Alternate procedures or redundant controls.

◆ 3. Risk Management Fundamentals

Term	Meaning
Risk	Possibility & impact of damage from a threat exploiting a vulnerability.
Information Risk Management (IRM)	Identify, assess, reduce & maintain risk to acceptable level.
Vulnerability	Weakness exploitable by a threat.
Threat	Potential danger exploiting a vulnerability.
Threat Agent	Entity carrying out an attack.
Exposure	Potential for loss/damage.
Countermeasure	Safeguard mitigating risk.

Chain: *Threat Agent → Threat → Vulnerability → Risk → Damage/Exposure → Countermeasure.*

◆ 4. Data Loss / Exfiltration

Definition: Unintentional or intentional loss/leak/theft of organizational data.

Consequences:

- Brand damage & reputation loss
- Competitive disadvantage / loss of customers
- Revenue loss + legal action + fines
- Costly notification & recovery process

Vectors (Causes):

- Unencrypted devices
- Cloud storage leaks
- Removable media & hard copies
- Improper access controls
- Email / Social media sharing

◆ 5. BYOD & COPE

Concept	Description	Benefits	Drawbacks / Risks
BYOD (Bring Your Own Device)	Employees use personal devices for work.	Boosts productivity, comfort, cost saving.	Malware injection, data leak, device theft, IT overload.
COPE (Corporate-Owned, Personally Enabled)	Company issues devices but allows limited personal use.	Greater control, can wipe data, control apps/networks.	Higher cost for organization.

Security Measures (MDM): Encryption, PIN policy, remote wipe, DLP, root detection, device tracking, security audits.

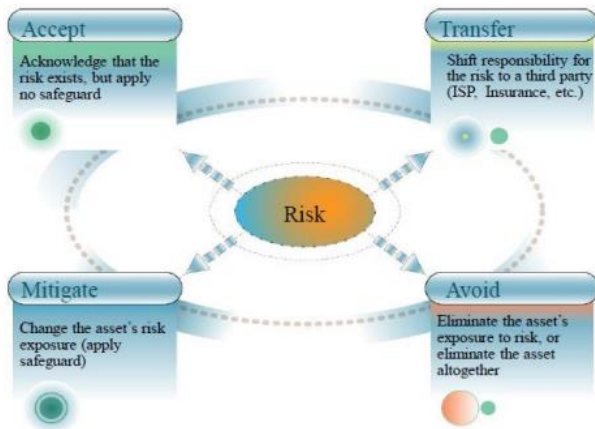
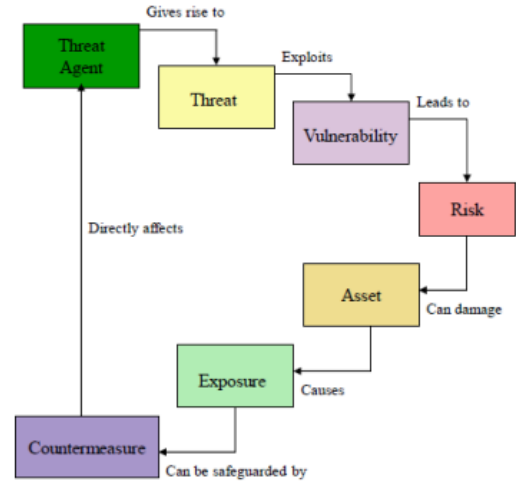
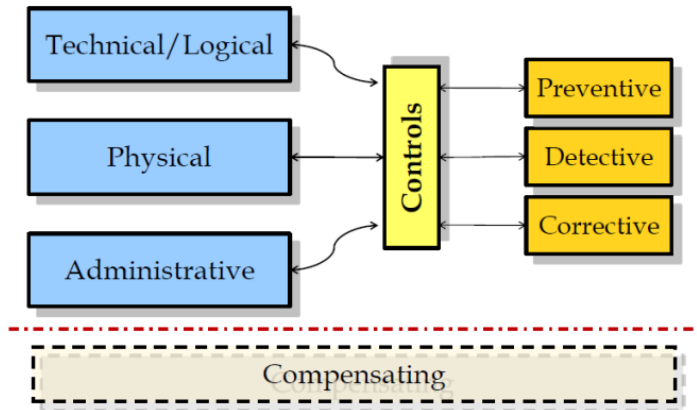
◆ 6. Hackers & Hacking Roles

Category	Description
White Hat	Ethical hackers – perform authorized testing for good purposes.
Gray Hat	Cross ethical lines without malice (e.g., publicly disclose vulnerability).
Black Hat	Malicious attackers for personal gain / crime.

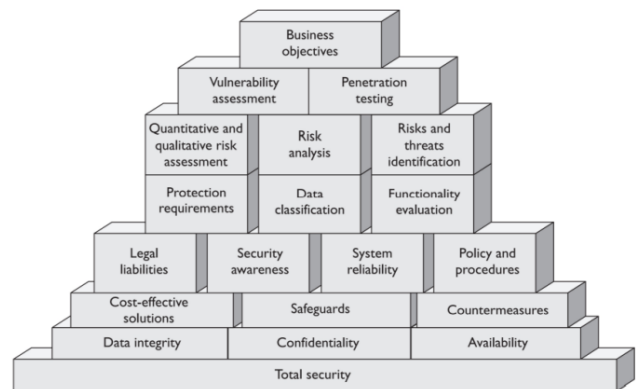
Modern Hacker Titles

Type	Description
Script Kiddies	Unskilled users running others' tools for fun / fame.
Vulnerability Brokers	Find exploits → report or sell for rewards.
Cyber Criminals	Financially motivated black hats.
Hacktivists	Political/social protest hackers (e.g., Anonymous, Syrian Electronic Army).
State-Sponsored Hackers	Government-funded cyber warfare agents (e.g., Stuxnet on Iran nuclear plants).

Security Controls



Comprehensive Security Model



3) Lecture 3: Information Risk Management – GRC & COBIT

◆ 1. Governance – Risk Management – Compliance (GRC)

Definition:

An *umbrella term* combining governance, risk, and compliance across enterprise operations not limited to IT.

Area	Core Meaning	Focus
Governance	Exercise of authority and control to direct and manage.	Strategic decisions, stakeholder value.
Risk Management	Managing exposure to loss; identifying & mitigating risks.	Prevent/minimize negative impact.
Compliance	Adhering to laws, regulations, standards, ethics.	Legal + policy alignment.

Simplified view:

- Governance = manage effectively
- Risk = mitigate effectively
- Compliance = obey rules & standards

Types of GRC:

Corporate GRC | Project GRC | IT GRC | Environmental GRC | Economic / Financial GRC

◆ 2. IT GRC (Specific to Information Systems)

Component	Role
IT Governance	Defines decision structures & accountability mechanisms.
IT Risk Management	Identifies & reduces potential IT-related risks.
IT Compliance	Ensures conformity to laws, corporate duties & industry standards.

Trend: Earlier IT GRC efforts were scattered → now need a **Holistic Approach** = centralized, integrated GRC model.

◆ 3. COBIT Framework (for IT GRC)

Feature	Description
Full Name	<i>Control Objectives for Information and Related Technology</i>
Developed by	ISACA (Information Systems Audit and Control Association)
Latest Version	COBIT 5
Purpose	Guide IT governance & management to deliver value while managing risk.
Goal	Balance → Benefits vs Risks vs Resource Use

COBIT 5 Highlights

- Enterprise-wide, end-to-end governance & management.
- Holistic → covers all stakeholders + IT-related responsibilities.
- Generic → applies to any industry / organization size.



◆ 4. COBIT 5 Principles (5 Core)

1 Meeting Stakeholder Needs

- Translate stakeholder expectations into actionable goals.
- Govern decisions by asking:
 - Who receives benefits?
 - Who bears risk?
 - What resources are required?
- Uses **Goals Cascade** → Stakeholder Needs → Enterprise Goals → IT Goals → Enabler Goals.

(Other COBIT 5 principles, though not shown here but exam-relevant, are typically:)

2. Cover the Enterprise End-to-End

3. Apply a Single Integrated Framework

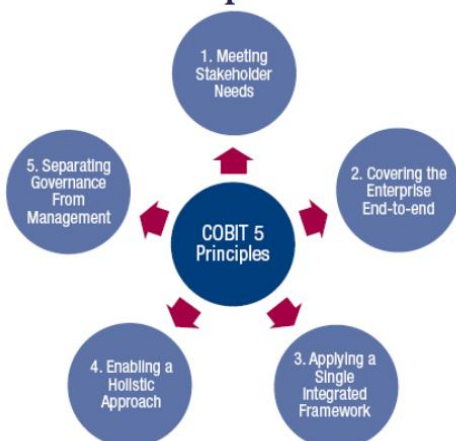
4. Enable a Holistic Approach

5. Separate Governance from Management

◆ 5. COBIT 5 Enablers

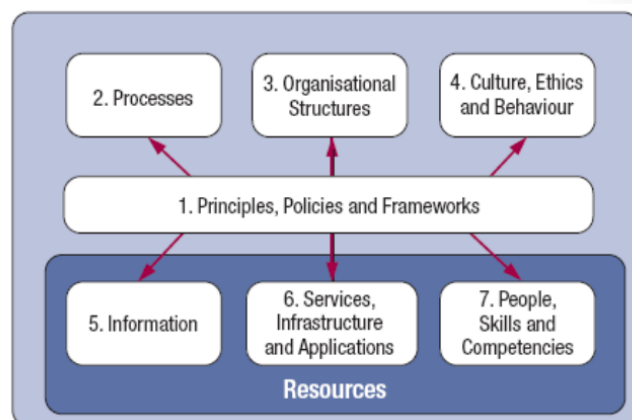
- Mechanisms that help implement governance & management:
Policies, Processes, Organizational Structures, Culture, Information, Services & Infrastructure, People & Skills.

COBIT 5 Principles



Source: COBIT® 5, figure 2. © 2012 ISACA® All rights reserved.

COBIT 5 Enablers



4) Lecture 3 Part 2: Information Risk Management – GRC & COBIT

◆ 1. The Big Picture

Enterprise Risk Management (ERM) has several branches:

- Financial Risk Management
- Information Risk Management (IRM)
- Other Risk Programs (Operational, Legal, Strategic, etc.)

◆ 2. 5-Step Risk Management Process

Step	Key Focus	Notes
1. Risk Identification	Identify internal & external risks	Continuous process; use expert knowledge (e.g., Pen Testing), creativity, and cross-department involvement.
2. Qualitative Analysis	Assess & prioritize risks by probability × impact	Impact = financial + legal + reputation + safety; use rating scales (Very Low → Very High).
3. Quantitative Analysis	Assign monetary values to risks	More precise but time-intensive; useful for decision-making & justification.
4. Response Planning	Choose and apply treatment options	Avoid / Mitigate / Transfer / Defer / Accept.
5. Monitor & Control	Track effectiveness and update	Continuous review + stakeholder communication.

◆ **3. Qualitative Risk Analysis – Scales**

Probability	Description	Numeric Scale
Very Low	Unlikely to occur	1
Low	May occur occasionally	4
Moderate	Likely as not	6
High	Likely to occur	8
Very High	Almost certain	10

Impact	Description	Numeric Scale
Very Low	Negligible	1
Low	Minor impact	2
Moderate	Notable impact	4
High	Substantial impact	8
Very High	Threatens company success	16

Formula:

Risk Rating = Probability × Impact

Example:

A ($4 \times 8 = 32$) > C ($1 \times 16 = 16$) > B ($6 \times 2 = 12$)

◆ 4. Quantitative Risk Analysis – Key Variables

Variable	Formula / Meaning	Example
Exposure Factor (EF)	% of asset loss from a threat	20 %
Single Loss Expectancy (SLE)	Asset Value × EF	Rs 50 000 × 20 % = Rs 10 000
Annualized Rate of Occurrence (ARO)	How often per year the event happens	e.g., 0.2
Annualized Loss Expectancy (ALE)	SLE × ARO	Rs 10 000 × 0.2 = Rs 2 000
Safeguard C/B	(ALE before – ALE after) – annual cost of control	Positive = cost effective

◆ 5. Determining Asset Value

Type	Approach
Tangible Assets	Ask IT manager for hardware/software costs; add installation, depreciation, contingency (~10 %).
Intangible Assets	Estimate fair market or income-producing value; consider trade secrets & IP; involve senior management.

◆ 6. Response Planning – Standard Options

Response	Description
Avoid	Eliminate risk source (change plan).
Mitigate	Reduce probability or impact.
Transfer	Shift impact / ownership (e.g., insurance).
Defer	Delay actions until risk less likely.
Accept	Prepare contingency, no plan change.

◆ 7. Monitoring & Control

- Track identified risks and response effectiveness.
- Identify new/changed risks → re-enter Steps 2-4.
- Keep stakeholders informed; retire controls when no longer needed.

◆ 8. Methodologies (Preview)

Next lecture → **OCTAVE / OCTAVE-Allegro**

(Operationally Critical Threat, Asset & Vulnerability Evaluation)

5) Lecture 4: OCTAVE Risk Evaluation Framework

- ◆ **OCTAVE** = *Operationally Critical Threat, Asset, and Vulnerability Evaluation*

A **methodology** for identifying and evaluating information security risks to assets.

Aspect	Description
Developed by	<i>Christopher Alberts, Carnegie Mellon University (CMU)</i>
Purpose	Risk-based information security assessment & strategic planning
Approach	Top-down, qualitative, process-driven, self-directed (by internal staff)
Focus	<i>Strategy over technology</i> → organizational needs first

◆ 2. Key Characteristics

Feature	OCTAVE	Other Frameworks
Focus	Strategic (organization-wide)	Tactical (system-based)
Orientation	Security practice-oriented	Technology-oriented
Direction	Top-down	Bottom-up
Leadership	Self-directed by internal team	Expert-led
Evaluation	Organization-wide	System-level

◆ 3. OCTAVE Team Structure

- **Operational (Business) Units**
- **IT Department**

Cross-functional team → aligns business objectives with IT risks.

◆ 4. OCTAVE Functionality

- Identify **critical organizational assets**
- Analyze **threats** and **vulnerabilities**
- Evaluate risks **in operational context**
- Develop **protection strategies & mitigation plans**

◆ 5. OCTAVE 3-Phase Process

Phase	Objective	Sub-Processes
1. Build Asset-Based Threat Profiles	Identify & document threats to critical assets	(1) Identify critical assets, (2) Identify security requirements, (3) Identify organizational vulnerabilities, (4) Create threat profiles
2. Identify Infrastructure Vulnerabilities	Review technology components supporting critical assets	(5) Identify network paths & IT components, (6) Evaluate vulnerabilities
3. Develop Security Strategy & Mitigation Plan	Analyze risk & create actionable strategies	(7) Conduct risk analysis, (8) Develop protection & mitigation plan

◆ 6. Process 4 – Threat Profile Example

Attribute	Description
Asset	What needs protection (e.g., student records in S01 server).
Access	How actor interacts (network, physical).
Actor	Insider / Outsider / Natural event.
Motive	Deliberate or accidental.
Outcome	Violation type:

- Disclosure – Unauthorized access
- Modification – Tampering / inconsistency
- Interruption – Destruction / unavailability
- Fabrication – Creation of false data

Example:

- *Actor*: insider accidentally entering wrong data → *Outcome*: modification
- *Actor*: outsider using records for gain → *Outcome*: disclosure

◆ 7. Phase 3 – Risk Analysis & Strategy

- Analyze threats identified in earlier phases.
- Develop:
 - **Risk Profiles** (impact + probability)
 - **Protection Strategies**
 - **Mitigation Plans**
 - **Next Steps (with senior management approval)**

Impact areas:

Reputation / Customer Confidence • Life/Health • Legal Penalties • Financial • Other

◆ 8. OCTAVE Variants

Variant	Focus / Use	Organization Type
OCTAVE (original)	Large organizations (≥ 300 employees)	Enterprise level
OCTAVE-S	Simplified for small organizations	≤ 300 employees
OCTAVE-Allegro	Focuses specifically on information assets (data, software, etc.)	All organization sizes

◆ 9. OCTAVE-S Details

- Developed (2003) for smaller orgs with simple hierarchy.
- **Team size:** 3–5 people familiar with business & security.
- **Deliverables:**
 - Organization-wide protection strategy
 - Risk mitigation plans
 - Action list (short-term steps)
 - Asset inventory & risk profiles
 - Security practice survey results

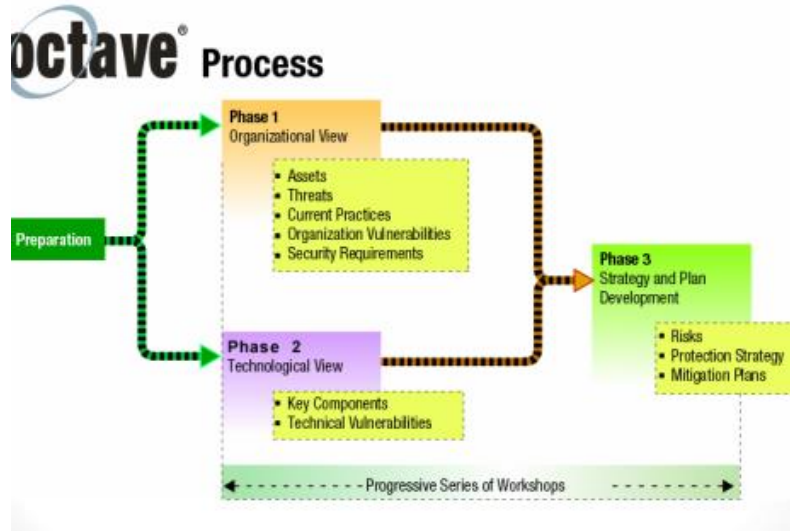
◆ 10. OCTAVE-Allegro Highlights

Aspect	Description
Developed	2007
Focus	Information assets – where stored, processed, transmitted
Strengths	Well-documented, flexible, cheap, self-led, comprehensive
Weaknesses	Complex, qualitative (no math), single-asset focus, slower results, poor for future threats

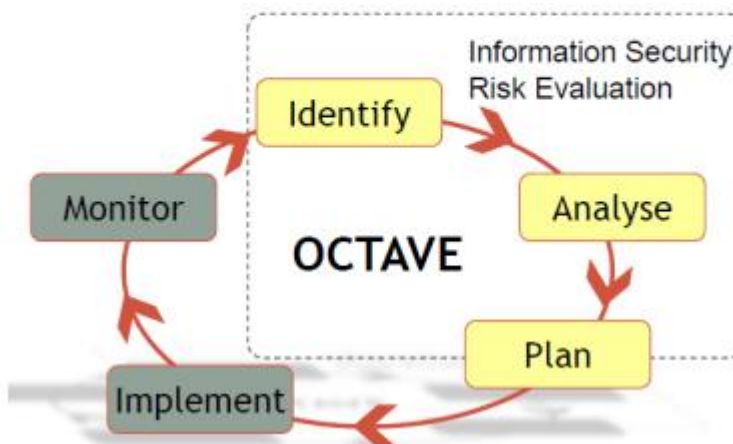
◆ 11. Discussion & Evaluation

- **Flexible:** Choose relevant parts (cost & time saving).
- **Downside:** Risk of skipping essential parts.
- **Self-led:** Lower cost but less expert accuracy.
- **Qualitative:** Simplicity > mathematical accuracy.
- **Uses:** Expected Value Matrix (not formulas).

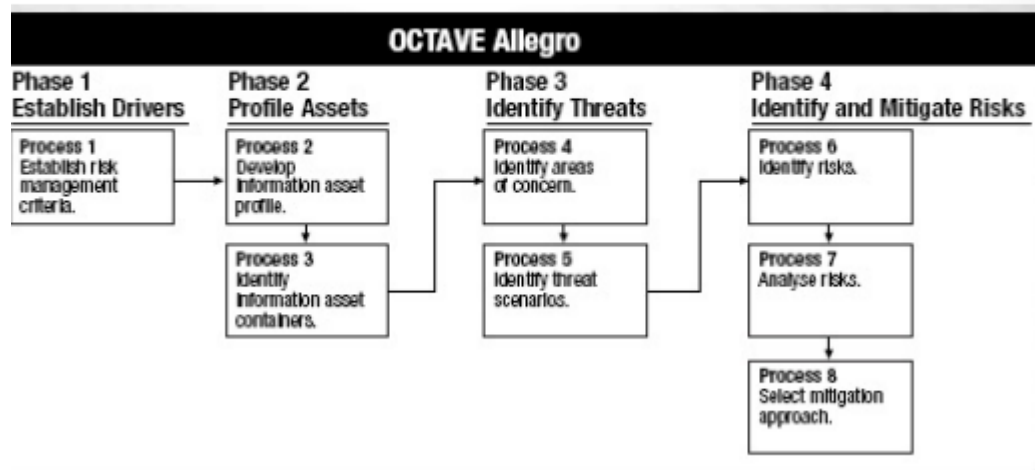
OCTAVE Phases - Overview



OCTAVE-S Scope



OCTAVE-Allegro



6) Lecture 5: Introduction to Cryptography & Historical Ciphers

◆ 1. Cryptology Overview

Cryptology = Cryptography + Cryptanalysis

Branch	Description	Sub-Types
Cryptography	Creation of ciphers & protocols to secure data	Symmetric / Asymmetric, Block / Stream, Protocols
Cryptanalysis	Breaking or analyzing cryptographic systems	Brute-force, analytical, mathematical, social engineering

◆ 2. Basic Facts

- **Oldest use:** $\approx$ 2000 B.C. (Egypt).
- **Pre-1976:** All encryption = *Symmetric*.
- **1976 onwards:** *Asymmetric (Public-Key)* by Diffie–Hellman–Merkle.
- **Modern systems:** Hybrid – symmetric for data encryption + asymmetric for key exchange / signatures.

◆ 3. Symmetric Cryptography

Also called: Private-key / Single-key / Secret-key encryption.

Scenario:

- Alice $\leftrightarrow$ Bob communicates over an insecure channel.
- Oscar (the attacker) intercepts data but cannot understand it.

Equations:

$$y = eK(x), x = dK(y)$$

- x = plaintext, y = ciphertext, K = key.
- Secure if and only if K remains secret.
- **Problem:** Key must be securely shared first (“key distribution problem”).

◆ 4. Cryptanalysis & Security Principles

- **Kerckhoff's Principle:**

A cryptosystem must remain secure even if everything is known except the key.

- Only use public, well-tested algorithms (e.g., AES).

- **Attack types:**

- Brute-force
- Mathematical analysis
- Implementation attacks (e.g., side-channel)
- Social engineering

◆ 5. Brute-Force Attack

Key Length (bits)	Key Space	Approx. Security Lifetime
64 bits	2^{64}	Short term (few days / months)
128 bits	2^{128}	Long-term (several decades if no quantum computers)
256 bits	2^{256}	Very long-term (resistant even to future quantum attacks)

Brute-force needs at least one plaintext–ciphertext pair (x_0, y_0) .

◆ 6. Historical Ciphers – Classical Techniques

Cipher	Mechanism	Example / Note
Substitution Cipher	Replace each letter with another fixed letter (A→k, B→d ...)	Easy to analyze by frequency.
Attack 1: Brute-Force	26! possible keys $\approx 2^{88} \rightarrow$ impractical.	
Attack 2: Frequency Analysis	Common letters (“E”, “T”) reveal mapping.	
Caesar Cipher	Shift alphabet by 3 letters (A→D, B→E)	Simple substitution example.
Vigenère Cipher	Uses repeating keyword (“LEMON”) forming multi-alphabet encryption.	Slightly stronger than Caesar.
Columnar Transposition	Rearranges plaintext rows/columns without changing letters.	Adds confusion by reordering.

◆ 7. The ENIGMA Machine

- **Electro-mechanical cipher** (Germany WWII).
- Combined rotors + electrical circuits to constantly change substitution mappings.
- **Invented:** 1918 → used by German Army (1928 onwards).
- **Broken** by Allied cryptanalysts at Bletchley Park → shortened WWII.

How it worked:

- Typing plaintext on keyboard → signal passed through rotors → lamp indicated ciphertext.
- Security came from rotor movement and daily key settings.

7) Lecture 6: Symmetric Ciphers

◆ 1. Position in Cryptology

Cryptology → **Cryptography** + **Cryptanalysis**

Cryptography →

- *Symmetric Ciphers* (Block + Stream)
- *Asymmetric Ciphers* (Public-key)
- *Protocols*

Symmetric encryption = same key used for encryption and decryption.

◆ 2. Stream Ciphers

Concept	Description
Origin	Invented in 1917 by <i>Gilbert Vernam</i>
Operation	Encrypt data bit-by-bit using a key stream
Common Uses	Fast, lightweight → mobile/embedded (e.g., A5/1 in GSM)
Mathematics	Encryption & decryption use XOR (mod 2 addition):
Encryption → $y_i = x_i \oplus s_i$ Decryption → $x_i = y_i \oplus s_i$	
Property	Perfect secrecy if key stream is random (like one-time pad)
Performance Example (Pentium4)	RC4 → 211 Mbit/s vs AES (51 Mbit/s), DES (36 Mbit/s), 3DES (13 Mbit/s)

Advantages: Simple, high throughput

Limitation: Must never reuse same key stream

◆ 3. Block Ciphers

Concept	Description
Operation	Encrypt fixed-size blocks (e.g., 64 bit, 128 bit)
Common Use	Internet & data storage encryption
Design Principles (Claude Shannon)	
Confusion	Obscure relation between key and ciphertext (via substitution)
Diffusion	Spread plaintext influence across ciphertext (via permutation)
Product Cipher	Combines confusion + diffusion in multiple rounds → changing 1 plaintext bit flips $\approx$ half ciphertext bits

◆ 4. Common Symmetric Algorithms

DES – Data Encryption Standard

- Developed by **IBM**; standardized 1976
- Block size = 64 bits | Key = 56 bits
- **Type:** Symmetric Block Cipher
- **Strength:** Weak today – EFF “Deep Crack” broke DES key in 56 hours
- **Use only for short-term protection**

Recommendations:

- Change keys often | Send key via secure channel

Rating	Note
Medium Speed / Resource Use	56-bit key easily brute-forced
Replaced by 3DES / AES	

3DES (Triple DES / TDES)

- Successor to DES (standardized 1977)
- Performs **Encrypt → Decrypt → Encrypt** on 64-bit blocks.
- Uses 1 / 2 / 3 different keys.
- **Key sizes:** 112 or 168 bits (effective security $\approx$ 112 bits).
- 256× stronger than DES but slower.

Metric	Value
Time to crack ($\approx 2^{55}$ keys per s)**	$\sim$ 4.6 billion years (current tech)**
Speed	Low (3 passes per block)
Status	Conservative choice but being phased out

AES – Advanced Encryption Standard (Rijndael)

- **FIPS-approved (2001)** replacement for DES/3DES.
- **Block size:** 128 bits
- **Key lengths:** 128 / 192 / 256 bits (any combination with block size).
- **Extremely secure + fast** – used worldwide.

Rating	Note
High speed / Low resource	Standard since 2001
Time to crack @ 2^{55} keys/s	$\approx$ 149 trillion years (128-bit key)
Current global standard	Used in VPNs, SSL/TLS, Wi-Fi (WPA2/3)

RC Algorithms – (“Rivest Codes”)

Invented by **Ron Rivest** (MIT / RSA co-founder).

Fast, flexible key sizes – used widely in software & networking.

Algorithm	Year	Type	Key Size	Notes
RC2	1987	Block	40 – 64 bits	Drop-in DES replacement
RC4	1987	Stream	1 – 256 bits	Used in SSL/WEP; fast but now deprecated
RC5	1994	Block	0 – 2040 bits (128 recommended)	Variable block/key size
RC6	1998	Block	128–256 bits	AES finalist (based on RC5) – secure & efficient

8) Lecture 7: Public Key Cryptography (Asymmetric Encryption)

◆ 1. Symmetric Cryptography – Quick Recap

- Same secret key **K** used for both **encryption & decryption**.
- Secure but suffers from **key distribution problem** (how to share K securely).
- Example: AES, DES, 3DES.
Limitation: Both parties must possess the same secret key before communication.

◆ 2. Public Key (Asymmetric) Cryptography

Aspect	Description
Introduced	1976 by <i>Whitfield Diffie & Martin Hellman</i>
Concept	Split the key:
• Public key (Kpub) – shared with everyone	
• Private key (Kpr) – kept secret	
Principle	Anyone can encrypt with the public key, but only the private key holder can decrypt.
Security Basis	One-way mathematical functions – easy to compute, infeasible to reverse.
Analogy	A mailbox – anyone can drop letters in (public key), only the owner can open it (private key).

◆ 3. Key Pair Operation

Function	Example
Encryption	Using Kpub (recipient)
Decryption	Using Kpr (recipient)
Signature	Using Kpr (sender)
Verification	Using Kpub (sender)

◆ 4. Limitations of Public-Key Systems

- **~1000× slower** than symmetric encryption.
- Can encrypt **only small amounts of data** (inefficient for bulk use).

Solution: Hybrid Cryptography

Use both asymmetric and symmetric encryption together.

◆ 5. Hybrid Cryptography Model

Stage	Algorithm Type	Purpose
1. Key Exchange	Asymmetric (e.g., RSA, Diffie-Hellman)	Securely share a random session key
2. Message Encryption	Symmetric (e.g., AES)	Fast encryption using that session key

Advantage:

Combines **security** of public-key with **speed** of symmetric systems → key distribution problem solved.

◆ 6. Mathematical Foundations – One-Way Functions

Family	Mathematical Problem	Examples
Factoring Integers	Hard to factor large composite numbers	RSA
Discrete Logarithm	Given $a, y, m \rightarrow$ find x in $a^x = y \bmod m$	Diffie–Hellman, ElGamal, DSA
Elliptic Curve (EC)	Generalization of discrete log problem	ECDH, ECDSA

These are computationally hard but not yet mathematically proven “impossible.”

◆ 7. Major Algorithms

RSA (Rivest–Shamir–Adleman)

- Proposed in 1977 (MIT).
- Based on **integer factorization**.
- **Applications:**
 1. Key transport (for symmetric keys)
 2. Digital signatures
- Still the most widely used asymmetric system; ECC is a faster modern alternative.

Diffie–Hellman Key Exchange (DHKE)

- Introduced in 1976 by *Diffie & Hellman*.
- **Purpose:** Securely exchange keys, not for encrypting data itself.
- Foundation for **ElGamal** encryption and used in **SSH, TLS, IPSec**.

Each side generates a private value $\rightarrow$ computes a public value $\rightarrow$ exchanges $\rightarrow$ derives same shared secret.

◆ 8. Digital Signatures

Purpose	Ensure authenticity, integrity, non-repudiation.
Scenario	Alice orders a pink car → later denies it. Bob needs proof Alice actually signed.
Solution	Alice signs with her private key , Bob verifies using her public key .

Concept:

Signature = $f(\text{Message}, K_{\text{pr}})$

Verification = $f^{-1}(\text{Signature}, K_{\text{pub}})$

Only the holder of the private key can generate a valid signature.

Signature changes for every message (depends on message content).

◆ 9. Certificates & Public Key Infrastructure (PKI)

Certificates

- Digitally signed proof that binds a user's **identity** to their **public key**.
- Issued by a trusted third party called a **Certificate Authority (CA)**.
- **Structure:**
- Certificate = (Kpub, ID(User), Signature by CA)
- Example:
Cert(Alice) = (KpubA, ID(Alice), sigKCA(KpubA, ID(Alice)))

Real-world Example

- **Standard:** X.509
- Contains fields such as version, serial number, subject, validity, public key, and CA's signature.

◆ 10. PKI – Public Key Infrastructure

The full ecosystem for managing keys and certificates:

- Certificate Authorities (CAs)
- Registration Authorities
- Certificate Revocation Lists (CRLs)
- Trust Chains (cross-certification between CAs)

Challenges:

1. Cross-certification between different CAs (building a *chain of trust*).
2. Revocation (if certificate compromised → listed in CRL).

9) Lecture 8: Hash Functions & MACs

♦ 1. Motivation – Why We Need Hash Functions

- Directly signing long messages (e.g., 256 MB file) is **inefficient and insecure**.
 - ✗ High computational cost (millions of RSA operations)
 - ✗ Large message overhead
 - ✗ Risk of partial message modification

Solution: Use a **hash (digest)** of the message → sign the short digest instead.

→ Faster + same integrity protection.

♦ 2. What Is a Cryptographic Hash Function?

Property	Description
Purpose	Maps input of arbitrary length → fixed-length output (128–512 bits).
Output	Short “fingerprint” / message digest uniquely representing the input.
Efficiency	Easy to compute, hard to reverse.
Diffusion	A single-bit change in input drastically changes the hash output.

♦ 3. Digital Signature Using a Hash Function

Step	Operation	Description
1	$z = h(x)$	Compute hash of message
2	$s = \text{sig_Kpr}(z)$	Sign hash with sender's private key
3	Send (x, s)	Transmit both message + signature
4	Receiver computes $z' = h(x)$ and verifies using public key	Valid if $(s, z') = \text{true}$

Only the hash is signed → reduces computation and message size.

◆ 4. Security Properties of Cryptographic Hash Functions

Property	Description	Example
Pre-image Resistance	Hard to find any x that produces a specific $z = h(x)$.	Prevents reverse engineering.
Second Pre-image Resistance	Given x_1 , it's infeasible to find x_2 with $h(x_1) = h(x_2)$.	Prevents modification attacks.
Collision Resistance	Hard to find <i>any</i> pair (x_1, x_2) with same hash.	Prevents duplication/fraud.

All three are essential for digital signatures, data integrity, and authentication.

◆ 5. Example Algorithms

- **SHA-1** (160-bit digest, older standard)
- **SHA-2** (224, 256, 384, 512 bits — current secure version)
- **MD5** (128-bit, **insecure**)

◆ 6. Message Authentication Codes (MACs)

Definition:

A MAC is a cryptographic checksum appended to a message using a **shared secret key** — ensuring message integrity and authentication.

Step	Description
1	Sender computes $\text{MAC}_k(x)$ using secret key k
2	Receiver recomputes $\text{MAC}_k(x')$ and compares
✓	If identical → message integrity and authenticity verified

◆ 7. MAC vs Digital Signature

Feature	MAC	Digital Signature
Key Type	Symmetric (shared key k)	Asymmetric (private/public keys)
Provides Integrity?	✓ Yes	✓ Yes
Provides Authentication?	✓ Yes	✓ Yes
Provides Non-repudiation?	✗ No	✓ Yes
Speed	Very fast	Slower
Use Case	Network authentication (SSL/TLS, IPSec)	Legal / verified documents

◆ 8. Properties of Message Authentication Codes (MACs)

Property	Explanation
1 Cryptographic checksum	Produces authentication tag for message.
2 Symmetric	Both sender & receiver share the same secret key.
3 Arbitrary Input	Works on any message length.
4 Fixed Output	Produces constant tag length (e.g., 128 or 256 bits).
5 Integrity	Detects any message modification.
6 Authentication	Confirms the message source.
7 No Non-repudiation	Because both parties share the key.

◆ 9. MAC Implementation Methods

Method	Example	Description
Hash-based MAC (HMAC)	HMAC-SHA256	Uses hash + key for tag generation.
Cipher-based MAC (CBC-MAC)	AES-CBC-MAC	Uses block cipher output as tag.

10) Lecture 9: Access control

◆ 1. Definition

ITU-T X.800 defines **Access Control** as:

“The prevention of unauthorized use of a resource, including the prevention of its use in an unauthorized manner.”

Goals:

1. Prevent **unauthorized users** from accessing resources.
2. Prevent **legitimate users** from accessing **unauthorized resources**.
3. Enable users to access **only in an authorized way**.

◆ 2. Access Control Policies

Policy	Description	Example
Discretionary Access Control (DAC)	Access based on user identity and authorization rules . Users can grant access to others.	UNIX permissions (RWX).
Mandatory Access Control (MAC)	Access based on security labels (sensitivity levels) and clearances . Users cannot share access voluntarily.	SELinux, military systems.
Role-Based Access Control (RBAC)	Access based on roles assigned to users. Rights are tied to job functions, not individuals.	GitHub repo roles (Admin, Developer).

A system may combine **DAC, MAC, and RBAC**.

◆ 3. Elements of Access Control

Element	Description	Example
Subject	Entity that requests access (user, process, app).	Owner, group, world.
Object	Resource to be protected.	File, record, mailbox, program.
Access Rights	Type of action permitted.	Read, Write, Execute, Delete, Create, Search.

◆ 4. Access Matrix Model

- **Matrix Rows:** Objects.
- **Matrix Columns:** Subjects.
- Each entry = allowed operations of subject on object.
- Typically sparse → implemented as **Access Control Lists (ACLs)** or **Capability Tickets**.

◆ 5. Implementations

■ Access Control Lists (ACLs)

- Lists all **users/groups** allowed to access an object and their permissions.
- **Efficient** for finding *who* can access a given object.
- **Limitation:** Hard to check all objects accessible by a single user.
- May include *default/public entries* (least privilege principle).

■ Capability Tickets

- Each **user/subject** holds a list (ticket) describing accessible objects and permissions.
- Users can **loan** or **share** tickets.
- OS must **protect and validate** tickets — they must be **unforgeable**.
- For distributed systems → implemented as **tokens** (e.g., OAuth tokens, cryptographic MACs).

Comparison	ACL	Capability Ticket
Focus	Objects	Users
Easier to find	Who can access an object	What a user can access
Security issue	Unauthorized grant	Forgery of ticket

◆ 6. Role-Based Access Control (RBAC)

Concept	Description
Role	A job function or responsibility within the organization.
Assignment	Users ↔ Roles (many-to-many).
Rights	Permissions are assigned to roles, not directly to users.
Activation	Roles can be assigned statically (permanent) or dynamically (temporary).

Advantages:

- Simplifies management.
- Reduces risk of privilege misuse.
- Scales for enterprise environments.

◆ 7. Access Control Requirements

Requirement	Description
Reliable Input	System must ensure all input (user identity, IP, MAC) is trustworthy; needs strong authentication first.
Fine & Coarse Specifications	Control access at both detailed (record/field level) and broad (system/module level) granularity.
Least Privilege	Grant only minimal rights needed to perform tasks. Limits accidental or malicious damage.
Separation of Duty	Split sensitive operations among multiple users to prevent abuse (e.g., dual approval).
Open vs Closed Policy	<i>Closed:</i> Only authorized accesses allowed (default-deny).
<i>Open:</i> All accesses allowed unless explicitly denied.	
Policy Combination & Conflict Resolution	Handle overlaps between multiple policies (e.g., DAC + RBAC). Define priority or resolution rules.
Administrative Policy	Define who can modify access rules or authorization databases.
Dual Control	Tasks require cooperation of ≥ 2 individuals (e.g., financial approvals).

11) Lecture 10: User Authentication

◆ 1. Definition (RFC 2828)

Authentication is the process of verifying an identity claimed by or for a system entity.

Steps:

1. **Identification** – Present an identifier (e.g., username).
2. **Verification** – Present or generate authentication data proving the binding between user and ID.

◆ 2. Importance of Identification

- Determines **authorization** (what user can access).
- Defines **privileges** (e.g., admin > guest).
- Used in **discretionary access control (DAC)** for enforcing read/write/execute rights.

◆ 3. Common Vulnerabilities

- Weak or single-factor authentication methods.
- Users bypassing or disabling authentication.
- Poor protection of stored credentials (no hashing/salting).
- Unencrypted transmission of credentials over networks.
- Social-engineering or phishing attacks (users revealing passwords).

◆ 4. Four Authentication Factors

Category	Description	Examples
Something you know	Knowledge factor	Password, PIN, security question
Something you have	Possession factor	Smart card, ID token, key fob
Something you are	Static biometric	Fingerprint, retina, face
Something you do	Dynamic biometric	Voice, handwriting, typing rhythm

Best Practice: combine $\geq 2 \rightarrow$ **multi-factor authentication (MFA)**

◆ 5. Password-Based Authentication

- Most widely used method.
- System stores **hash of password** (not plaintext).
- When logging in, user's hash is compared with stored hash.
Vulnerable to multiple attack types.

◆ 6. Password Vulnerabilities & Countermeasures

Attack Type	Description	Countermeasure
Offline dictionary	Attacker obtains password file & tests hashed wordlists	Protect password file, intrusion detection, force password reset
Specific account	Guess repeatedly for one account	Account lockout after ≈ 5 attempts
Popular password	Try common passwords across many users	Password policies, IP / pattern monitoring
Targeted guessing	Use personal info to guess	Enforce complex passwords, user training
User mistakes	Writing or sharing passwords, social engineering	Training, behavioral monitoring, simpler + MFA
Workstation hijacking	Logged-in but unattended device	Auto-logout after inactivity, intrusion detection
Reuse across systems	Same password everywhere	Enforce unique passwords per system
Electronic monitoring	Intercepting network passwords	Use encrypted challenge-response / Kerberos

◆ 7. Multi-Factor Authentication (MFA)

- Combines ≥ 2 authentication factors (e.g., password + token or biometric).
- **Two-factor authentication (2FA)**: “Something you know” + “Something you have.”
- Example: ATM card + PIN, or password + OTP app.

◆ 8. Single Sign-On (SSO)

Concept	Details
Definition	One centralized login provides access to multiple systems.
Advantages	Stronger passwords (only one needed), centralized admin, reduced resets, faster access.
Disadvantages	Complex cross-platform support, high development cost, single-point-of-failure risk.
Best Practice	Combine with MFA & biometrics for added protection.

◆ 9. Hashed Passwords with Salt

Process (Storing):

1. Generate random or pseudorandom **salt** for each password.
2. Compute hash(password + salt).
3. Store hash + plaintext salt in password file.

Process (Verification):

1. Retrieve salt + stored hash.
2. Hash (supplied password + stored salt).
3. Compare to stored hash.

Purposes of Salt:

- Prevent identical passwords from having same hash.
- Thwart offline dictionary / rainbow-table attacks (adds 2^b possibilities).
- Hide reused passwords across systems.

◆ 10. Remote User Authentication

Problem: Eavesdropping & replay attacks.

Solution: Challenge-Response Protocol (e.g., Kerberos).

Basic Flow:

1. User → ID to Server.
2. Server → Nonce r + hash function spec (challenge).
3. User → $f(r, h(P))$ response.
4. Server compares $f(r, h(P))$ with stored $h(P)$.
Prevents password transmission over network.

◆ 11. Password Selection Strategies

1. **User education** – teach strong, unique password creation.
2. **Computer-generated passwords** – random & hard to guess.
3. **Reactive checking** – detect weak passwords after creation.
4. **Proactive checking** – block weak passwords during creation.

12) Lecture 11: Firewalls, ACLs & Network Security

◆ 1. What is a Firewall?

A **firewall** is an electronic checkpoint between a protected network and an untrusted network.

Type	Description
Hardware Firewall	Network device (security gateway) that filters traffic between networks.
Software Firewall	Installed on host systems (e.g., Windows Defender Firewall).
Combined (Hybrid)	Uses both hardware and software to implement layered security ("Defense in Depth").

Purpose:

Prevent unauthorized access **to or from** a private network.

"Setting up a firewall without a security policy is like placing a steel door on a tent."

◆ 2. Firewall Core Functions

Category	Functions
Primary	- Packet Filtering (Layer 3/4)
- Stateful Inspection (Layer 3/4)	
- Application Layer Filtering	
Secondary	- Network Address Translation (NAT)
- VPN Tunneling	
- Proxy Server	

◆ 3. Packet Filtering Firewalls

Operate at: Network and Transport layers (IP + TCP/UDP headers).

Filter based on:

- Source / Destination IP
- Source / Destination Port
- Protocol (TCP/UDP/ICMP)

Advantages: Fast, inexpensive, flexible

Limitation: Cannot track sessions or dynamic ports (no context).

◆ 4. Access Control Lists (ACLs)

Used to define **permit/deny rules** for filtering traffic.

Concept	Description
Interface-bound	ACL applied <i>inbound</i> or <i>outbound</i> on interfaces.
Rule structure	One rule per line, checked sequentially.
Default rule	<i>Implicit deny</i> at end (clean-up rule).
Stealth rule	Protect firewall from direct access (usually first).

Best Practices:

- Block external packets with internal addresses → prevent **spoofing**.
- Block internal packets with external source addresses.
- Log but do **not respond** to dropped packets.
- Deny everything not explicitly allowed.

◆ 5. Example — Packet Filtering ACL

Rule	Source IP	Dest. IP	Port	Protocol	Action
A	*	10.1.0.1	*	*	Deny (stealth)
B	10.1.0.0	10.2.12.12	*	*	Deny
C	10.1.0.0	*	80	TCP	Allow (web access)
D	*	10.1.1.2	25	TCP	Allow (email upload)
E	*	10.1.0.20	80	TCP	Allow (web server)
I	*	*	*	*	Deny (clean-up)

◆ 6. Stateful Packet Inspection (SPI)

Tracks **session state** (SYN, ACK, FIN) and allows packets only if part of a valid connection.

Function

Example

Allows outgoing sessions

SYN → allowed outbound

Allows return traffic only

ACK → allowed inbound if session exists

Denies unsolicited inbound sessions Blocks unrequested SYN packets

Tracks dynamic ports

Permits FTP, VoIP etc. dynamically

Safer than static packet filters; reduces spoofing and replay attacks.

◆ 7. Firewall Benefits

- Protects internal network from external threats.
- Enforces centralized “choke point” for monitoring.
- Generates logs and alerts (audit trail).
- Reduces DoS exposure (blocks malicious packets).
- Controls inter-department or remote-office access.
- Supports additional services (NAT, VPN, proxy, IDS).

◆ 8. Firewall Drawbacks

- Cannot stop attacks **bypassing** the firewall (USB, insider threats).
- Weakest internal host can compromise entire network.
- Needs proper policy; people remain the weakest link.

◆ 9. Firewall Topologies

Topology	Description
Simple Filtering Router	Basic inbound/outbound filtering; low cost but minimal security.
Screened Host Firewall	Router + Bastion Host (public server) separated from LAN.
DMZ (Demilitarized Zone)	Dual-router design with public servers between internal & external networks.
UTM Firewall	Unified Threat Management – combines multiple tools (firewall, IDS, antivirus).

◆ 10. DMZ (Demilitarized Zone)

- Contains public-facing servers (Web, Email, DNS).
- Protected by **two firewalls**:
 - Outer: filters internet traffic → DMZ.
 - Inner: filters DMZ → internal network.
- **Anything not explicitly allowed is denied.**

◆ 11. Unified Threat Management (UTM)

A single appliance integrating:

- Firewall
- Anti-virus
- Anti-spam
- Intrusion Detection / Prevention (IDS/IPS)
- Web content filtering

Simplifies management and guards against **blended threats**.

Advanced form: **SIEM (Security Information & Event Management)**

◆ **12. SIEM (Security Information & Event Management)**

- Collects and correlates logs from multiple devices (routers, firewalls, servers).
- Detects patterns and relationships.

Examples: IBM QRadar, LogRhythm.

◆ **13. IDS / IPS**

System	Function
IDS (Intrusion Detection System)	Detects possible intrusions and alerts admins.
IPS (Intrusion Prevention System)	Detects + blocks attacks (drops packets, closes sessions).

Analysis Methods:

- **Signature-based:** Match known attack patterns.
- **Anomaly-based:** Machine learning (e.g., neural networks, K-means) detects abnormal traffic.

Problems: False positives / false negatives.

◆ 14. VPN (Virtual Private Network)

- Transmits private data securely over public networks.
- Uses **encryption & tunneling** to maintain confidentiality and integrity.
- Works at **Layer 3** (IP level).

VPN Tunneling:

- Encrypts data packets and hides source/destination IPs.
- Encrypted/decrypted at both tunnel endpoints.

Advantages:

- Conceals internal addresses
- Enables remote access securely

Disadvantages:

- Increases packet size (fragmentation risk)
- Reduces end-to-end confidentiality
- Adds latency (encryption overhead)

13) Lecture 12: Disaster Recovery & Business Continuity Planning (DRP & BCP)

◆ 1. Background

- **Information systems** face risks ranging from mild (e.g., temporary power outage) to severe (e.g., fire, natural disasters).
- Core focus = **Availability** (the “A” in CIA Triad).
- Ensured via **Disaster Recovery Planning (DRP)** and **Business Continuity Planning (BCP)**.

“More than half of SMEs affected by 9/11 never traded again.”

◆ 2. Key Definitions

Term	Definition
Disaster Recovery Planning (DRP)	Process of rebuilding IT operations and infrastructure after a disaster has occurred.
Business Continuity Planning (BCP)	Activities ensuring critical functions continue <i>during</i> disruption or displacement.
Focus	DRP → <i>After disaster</i>
Guideline	NIST SP 800-34 – provides official framework for DR & BC strategies.

◆ 3. Recovery Time Concepts

Term	Description
Interruption Window	Acceptable downtime before service must resume.
Service Delivery Objective (SDO)	Minimum service level during alternate mode.
Maximum Tolerable Outage (MTO)	Longest time system can operate in alternate mode before critical failure.

Goal: Reduce MTO and ensure SDO meets business needs.

◆ 4. Why Business Continuity?

- Businesses today are **highly dependent** on IT (e.g., e-commerce).
- Traditional DRP (focused only on data center recovery) is insufficient.
- BCP ensures **24×7 uptime** of critical services even amid disruptions.

◆ 5. When Business Continuity Applies

Triggered by any of the following:

- Equipment or application failure
- Power/telecom disruption
- Human error, sabotage, vandalism
- Malware, ransomware, hacking
- Strikes, terrorism, social unrest
- Fire or natural disasters (flood, earthquake, etc.)

◆ 6. Business Continuity Planning Team

- **Modern IS = distributed systems** → BCP is not just an IT task.
- Requires participation of **executives, managers, staff, vendors**.
- **BC/DR Coordinator:**
 - Maintains BCP documentation
 - Conducts periodic tests and updates
 - Distributes updated copies to responsible units

◆ 7. Business Continuity Site Options

Type	Description	Cost	Recovery Time
Cold Site	Empty facility with basic utilities; no IT setup.	Low	Long (days–weeks)
Warm / Mutual Backup Site	Shared or partially equipped site; moderate readiness.	Medium	Medium
Hot Site	Fully equipped with compatible hardware/software/network.	High	Short (hours)
Remote Journaling	Data continuously copied to offsite system every few hours.	Higher	Very short
Mirrored Site	Exact replica (real-time data mirroring). Transparent failover.	Very High	Instant

Rule: Higher cost → faster recovery.

◆ 8. High Availability Solutions

Technology	Function
RAID	Redundant disks – protects against drive failure.
Fault-Tolerant Server	Secondary server takes over automatically.
Distributed Processing	Load distributed among multiple servers; failover ready.
SAN (Storage Area Network)	Centralized storage network enabling remote backup & migration.

Goal: Achieve redundancy with optimal cost balance.

◆ 9. Third-Party DR/BC Providers

Before outsourcing, assess:

- Available **floor space**, redundancy, and backup capacity.
- Network redundancy, vendor relationships, and SLA terms.
- Budget and skilled personnel availability.

Example: LankaCom DR/BC services in Sri Lanka.

◆ 10. Phases of Preparing a BCP

Phase	Description
1. Project Initiation	Define BC objectives, scope, appoint BC committee.
2. Business/Risk Analysis	Conduct risk and impact analysis, cost-benefit study, and choose strategies.
3. Design & Development	Define teams, roles, strategies, activation criteria.
4. Implementation	Prepare recovery procedures, vendor contracts, alert recovery team.
5. Testing	Simulate disaster scenarios, evaluate response, document improvements.
6. Maintenance	Continuous review and improvement cycle.

◆ 11. Critical Concerns for BCP/DRP

- **Evacuation Plan:** Safety of people = top priority.
- **Disaster Declaration:** Define triggers & responsible decision-makers.
- **Roles & Responsibilities:** Assign clear recovery duties.
- **Alternate Operation Procedures:** Define manual/backup processes.
- **Resource Allocation:** Plan for sustained operation in recovery mode.
- **Offsite Plan Copies:** Store securely at alternate locations.

◆ 12. Legal & Regulatory Obligations

- Financial, telecom, and healthcare institutions must comply with national BC standards.
- Example: **Central Bank of Sri Lanka BCP Guidelines (2006)**.
- **SL-CERT** offers BC/DR consultancy and risk management guidance.